Monthly Intelligence Dispatch

December 2020

The Group-IB Monthly Threat Intelligence Dispatch (Group-IB MTID) is a monthly newsletter by Group-IB, an international company that specializes in preventing cyberattacks and developing information security products. The dispatch aims to provide information about the latest cyberthreats, criminal groups' attacks, data leaks, and malware. The document contains news about arrests, legal action against hacking groups, short-term forecasts, and recommendations to help take timely measures to reduce security risks and ensure protection against cyberthreats. Group-IB MTID is intended for internal use only and its distribution is not permitted.

Key findings

- For several months, threat actors spied on companies, government agencies, and users who downloaded an infected SolarWinds update. FireEye was among the victims.
- Bismuth, a nation-state hacking group active since 2012, started using cryptocurrency miners to avoid detection, disguise cyber espionage activity, and establish persistence in targeted systems.
- Group-IB experts established that the operators of the **FakeSecurity** JS sniffer were behind the **Raccoon** and **Vidar** stealer distribution campaign.
- In November 2020, Group-IB specialists detected new attacks by the UltraRank group, with a dozen of e-commerce websites infected with the **SnifLite** sniffer.
- The Brazilian company Embraer, which is the third biggest aircraft manufacturer in the world after Boeing and Airbus, fell victim to a ransomware attack last month.
- The Israeli company Habana Labs, an AI processor developer owned by Intel since 2019, was attacked by the Pay2Key ransomware.
- The developers of AgentTesla updated their stealer. The new capabilities include C&C communication through Telegram, TorProxy, and a password stealer.
- A French court sentenced Alexander Vinnik, a 41-year-old Russian national who founded the BTC-e cryptocurrency exchange, to five years in prison and ordered him to pay a €100,000 fine for money laundering.

SolarWinds

A new scandal broke in the United States: for several months, hackers had been spying on companies, government agencies, and users who downloaded an infected **SolarWinds** update. At least 18,000 SolarWinds customers may have been affected. SolarWinds' stock price fell 25% after the news about the breach first broke. Several IT giants fell victim, including **FireEye**, one of the world's largest cybersecurity solution providers. Threat actors successfully penetrated the company's internal network and stole tools that FireEye used for testing their customers' networks. The company published indicators of compromise and countermeasures on GitHub, which should help other companies identify whether the hackers used stolen FireEye tools to breach their networks. FireEye said that the tools stolen by the hackers did not contain zero-day exploits and that they ranged from simple scripts used for automating reconnaissance to entire frameworks similar to publicly available technologies such as CobaltStrike and Metasploit. However, many of them had already been available to security specialists.

Group-IB's Threat Intelligence & Attribution team discovered an interesting aspect of this case: as early as October 2017, a hacker from Kazakhstan known as **Fxmsp** sold access to http://solarwinds.com and http://dameware.com (remote control software from SolarWinds) on a popular underground forum. These seem to be one of the first companies access to which Fxmsp published. In just over three years, Fxmsp managed to gain access to corporate networks of companies based in more than 44 countries. According to the most conservative estimates, Fxmsp is likely to have made at least 1.5 million dollars throughout his activity. In June 2020, Group-IB released an analytical report called ***Fxmsp: "The invisible god of networks."*** The report exposes the identity of the hacker behind the username Fxmsp. A month later, the US Department of Justice unsealed an indictment charging a citizen of Kazakhstan, Andrey Turchin (aka Fxmsp), with various crimes.

Ocean Lotus

Facebook exposed an operation led by Ocean Lotus (aka APT 32) a nation-state APT group that works for the Vietnamese government. The researchers analyzed Ocean Lotus's activity on the social networking service, where the hackers used fake accounts for phishing purposes. The group targeted Vietnamese dissidents, foreign governments (including those in Laos and Cambodia), non-governmental organizations, news agencies, and businesses from various industries. Analysts at Facebook traced the hacking group to **CyberOne Group**, an IT company in Ho Chi Minh City. At the time, no technical details were mentioned, but Group-IB revealed attribution specifics obtained through its new **Threat Intelligence & Attribution** system.

Bismuth

Researchers from the **Microsoft 365 Defender Threat Intelligence** team detected that a nation-state hacking group called Bismuth used cryptocurrency miners to disguise cyber espionage activity and establish persistence in targeted systems. The group's targets were both the private sector and government institutions and one of the affected countries was Vietnam. The researchers' report says that miners helped the threat actors disguise their true intentions. While the threat actors' operational goals remained the same (conducting espionage and exfiltrating useful information) the deployment of coin miners provided another way for the attackers to monetize compromised networks. The threat group relies on a combination of social engineering and legitimate applications to load malicious DLL files.

FakeSecurity

In the summer of 2020, Group-IB specialists noticed an unusual campaign that involved the distribution of the Raccoon stealer. The stealer is well-known: it can collect system information, account information in browsers, bank card data, and information about crypto wallets. Raccoon is distributed as Malware-As-a-Service on a darknet forum together with Telegram channels to bypass C&C server blocking. Group-IB reconstructed the timeline of the malicious campaign and identified links with other parts of the threat actor infrastructure. Before distributing Raccoon, the threat actors worked with samples of another steal called Vidar in early 2020. They used attachments with malicious macros as well as fake webpages created using the Mephistophilus phishing kit. The distribution scheme reminded the experts of a pattern used by the operators of the FakeSecurity JS-sniffer family in a campaign described in November 2019. In addition to similarities in the toolkits used in the two attack campaigns, they both targeted e-commerce businesses. For instance, in May 2020, Group-IB experts discovered online stores infected with a modified JS sniffer from the FakeSecurity campaign. The JS sniffer was obfuscated using aaencode; to store code and collect stolen bank card data the threat actors used domains registered during the second wave of activity by the same registrars that registered the domains the experts identified in the campaign in question. As such, the operators of the FakeSecurity JS sniffer are behind the stealer distribution campaign.

UltraRank

In November 2020, Group-IB specialists detected a dozen of e-commerce websites infected with a sniffer whose code was obfuscated (or in other words hidden) using radix obfuscation. This type of obfuscation was usually used by several threat groups, including the notorious UltraRank group, which in five years attacked **691** online stores and **13** online services (the summer of 2020 saw the release of the report *UltraRank: The unexpected twist of a JS-sniffer triple threat*). Analysis confirmed the hypothesis. Deobfuscation revealed that the attacks involved a SnifLite family sniffer used by the UltraRank group and known to Group-IB specialists. Interestingly, when the attacks were discovered, part of the infrastructure of the group described in the report was still active; however, the threat actors did not use the existing domains for their new attacks and switched to a new infrastructure to store code and collect intercepted bank card data. Victor Okorokov, a Threat Intelligence & Attribution analyst at Group-IB, described all the details of the analysis in our blog.

Embraer

The Brazilian company Embraer, which is the third biggest aircraft manufacturer in the world after Boeing and Airbus, fell victim to a ransomware attack last month. The hackers who compromised the company's network published some of its confidential data after Embraer refused to negotiate with them and decided to recover their systems independently using backup copies without paying a ransom. The Embraer files were shared on a website hosted on the dark web, managed by the **RansomExx** ransomware gang (also known as Defray777). The data uploaded on the site included samples of employee details, business contracts, photos of flight simulations, and source code. The leak confirms that the hackers managed to steal data from the company's servers. The airplane maker said the attackers had "access to only a single environment," but did not mention what data was stolen.

TransLink

TransLink, the public transportation agency for the city of Vancouver, Canada, fell victim to a ransomware attack. The incident occurred on December 1, 2020 and resulted in Vancouver residents being unable to use their Compass metro cards or pay for new tickets via the agency's Compass ticketing kiosks. TransLink initially said the incident was a prolonged technical issue before the media learned about the true nature of the incident and forced the agency to come clean.

Pay2Key

The Israeli company Habana Labs, an AI processor developer owned by Intel since 2019, was attacked by the Pay2Key ransomware. Threat actors stole 53 GB worth of data, including business documents, source code, Windows domain account information, DNS zone information, and file listing from the Gerrit development code review system. The Pay2Key ransomware is a relatively new threat, which experts at Check Point and Profero described in November 2020. The ransomware operators were behind a series of recent attacks against Israeli businesses and Profero believes that Iranian threat actors may be behind Pay2Key. On average, the Pay2Key operators demand from 7 to 9 bitcoin from their victims, which is equivalent to about $135–173 with the current exchange rate.

PgMiner

Palo Alto Networks specialists discovered a botnet called PgMiner, which specializes in breaching poorly protected PostgreSQL databases with the aim of installing miners. The botnet relies on a well-known and well-established scheme: it randomly picks a public network range (e.g., 18.xxx.xxx.xxx) and then iterates through all IP addresses part of that range, searching for systems that have the PostgreSQL port (port 5432) exposed online. If PgMiner finds an active PostgreSQL system, the botnet moves from the scanning phase to its brute-force phase, where it shuffles through a long list of passwords in an attempt to guess the credentials for "postgres," the default PostgreSQL account. If PostgreSQL database owners have forgotten to disable this user or have forgotten to change its password, the hackers can access the database and use the PostgreSQL COPY from PROGRAM feature (the CVE-2019-9193 vulnerability was linked to it, which many in the PostgreSQL community did not recognize as a bug) to escalate their access from the database app to the underlying server and take over the entire OS. Once they have a more solid hold on the infected system, the PgMiner operators deploy a coin-mining application and attempt to mine the Monero cryptocurrency. According to the researchers, at the time of their report, the botnet only had the ability to deploy miners on Linux MIPS, ARM, and x64 platforms. The specialists also note that the PgMiner operators have been controlling infected bots via a command and control (C&C) server hosted on the Tor network and that the botnet's codebase appears to resemble the SystemdMiner botnet.

njRAT

Another piece of malware was found in the JavaScript package manager npm (Node Package Manager). This time, developers who installed the jdb.js and db-json.js packages were infected with the njRAT remote access Trojan. Both packages were removed from npm. The packages were created by the same author and were described as tools that help work with JSON files. Both packages were uploaded to npm in late November 2020, and users downloaded them more than 100 times before Sonatype discovered malware in them. According to Sonatype analysts, these packages contained a malicious script that was run after the developer imported and installed either of the two malicious libraries. The script performed basic reconnaissance on the infected host and then tried to download and run the "patch.exe" file (the file on VirusTotal), which later installed the njRAT Trojan on the affected machine. This malware is also known as Bladabindi and has been used by cybercriminals since at least 2015. To load njRAT without problems, the patch.exe loader changed the behavior of the local Windows firewall by adding a rule for its C&C server to the whitelist before downloading the malware.

Blackrota

Specialists at the Chinese company Qihoo 360 have discovered new malware called Blackrota, which targets vulnerable Docker servers. The malware is a simple backdoor Trojan that is, in fact, a simplified version of the CobaltStrike beacon implemented in the Go language. So far only a Linux version of the malware has been discovered and it is unclear how exactly it is being used. The researchers are not sure if there is a Windows version, if Blackrota is used to mine cryptocurrency, or if cybercriminals need powerful cloud servers for DDoS attacks.

Androzek	Microsoft warned about Adrozek, a new malware strain that infects user devices and modifies browsers and their settings in order to inject ads into search results pages. According to the company, the malware has been active since at least May 2020 and reached its absolute peak in August 2020 year when it controlled more than 30,000 browsers each day. The highest concentration of victims appears to be located in Europe, followed by South and South-East Asia. Currently, the malware is distributed via classic drive-by download schemes. Users are typically redirected from legitimate sites to shady domains where they are tricked into installing malicious software, which then proceeds to obtain persistence with the help of a registry key.
AgentTesla	The developers of AgentTesla updated their stealer. Group-IB analyzed AgentTesla's new capabilities. One of them is C&C communication through Telegram, which can become a major problem for organizations that use this messaging app. In addition, the TorProxy module helps threat actors conceal their real C&C servers.

Arrests and sentences

A French court sentencted Alexander Vinnik, a 41-year-old Russian national who founded the BTC-e cryptocurrency exchange, to five years in prison and ordered him to pay a €100,000 fine for money laundering for cybercriminals.

Alexander Vinnik

Vinnik initially faced a harsher sentence, but the French prosecutors were not able to prove that Vinnik was involved in the creation and distribution of the Locky ransomware, which was active in 2016–2017. Out of many charges related to Locky, extortion, and association to criminal activities, Vinnik was only found guilty of organized money laundering.

Vinnik was arrested in Greece, where he was vacationing in 2017, for his involvement in running BTC-e. At the time, the US authorities sought his extradition and said that Vinnik operated BTC-e as a front company for a money-laundering operation, knowingly receiving funds from hacks and other forms of cybercrime and helping crooks cash out stolen funds into fiat currency. According to a statement by the US Department of Justice, Vinnik not only managed a criminal group since 2011 and laundered over four billion dollars' worth of bitcoin through BTC-e, but also was involved in laundering money stolen from the Mt. Gox exchange, if not in hacking the exchange.

The arrest, however, was followed by prolonged legal proceedings, because as soon as Vinnik's arrest became public, the Russian authorities also filed an extradition request of their own, claiming that Vinnik was also a suspect in an investigation in Russia in relation to a 2013 €9,500 fraud charge. Many experts believe the Russian authorities were trying to bring Vinnik back home.

The extradition battle dragged on for more than a year and got even more complicated when the French authorities also filed their own extradition request asking to try Vinnik on 14 charges related to money laundering and hacking. The BTC-e founder is currently under arrest.

Arrests and sentences

Ryan Hernandez

Ryan Hernandez, a 21-year-old California resident, was sentenced to three years in prison and fined $260,000 for hacking Nintendo and stealing thousands of files with confidential data. In his teenage years, Hernandez and an associate used a phishing technique to steal credentials of a Nintendo employee: a malicious link was posted on the company's official forum requesting help with a technical issue. As a result, a tech support employee was infected with malware. This helped the attackers download a large body of data using stolen credentials. The information they stole included data on equipment, games (including unreleased ones), developer tools, the company's plans, and so on.

Sudhish Ramesh

A US court sentenced a former Cisco engineer named Sudhish Kasaba Ramesh to 24 months in prison and ordered him to pay a $15,000 fine for destroying servers that hosted infrastructure for the Cisco Webex Teams service in 2018. According to court document, Ramesh worked at Cisco from July 2016 to April 2018, when he resigned and joined another company. However, for reasons not mentioned in the indictment, five months later Ramesh accessed Cisco's cloud infrastructure hosted on Amazon's Web Services and ran a script that deleted 456 virtual machines that were supporting Cisco's video conferencing software WebEx Teams. These actions resulted in the temporary deletion of more than 16,000 Webex accounts and it took Cisco two weeks to recover the accounts and rebuild its systems, costing the company more than $2.4 million, with $1.4 million in employee time and $1 million in customer refunds. The tech giant brought the case to law enforcement as soon as it realized the Webex Teams outage was the result of intentional sabotage and not a server issue.

Forecasts and warnings

- Attacks against online stores involving malicious JavaScript for stealing bank card data have been an increasingly popular method of collecting large amounts of user payment information for subsequent resale. Group-IB specialists have compiled a list of recommendations that will help online businesses minimize potential damage, prevent infections, or discover existing malicious activity according to MITRE ATT&CK and MITRE Shield.

- Effective counteraction against new malware is only possible with innovative engineering solutions. Group-IB Threat Hunting Framework, for example, is a new type of system that is capable of protecting companies' networks and employees' workstations, including remote ones, thanks to patented cyberattack detection technologies; the Polygon module, which is a powerful tool for behavioral analysis of files extracted from email, network traffic, and file storage spaces; and integration with the Threat Intelligence & Attribution system.
- Data stolen by various hacker groups may be used by threat actors to gain access to email accounts or cryptocurrency wallets, commit financial fraud, or engage in espionage; such data can also be sold on hacker forums.
- The lack of strong communication channels between organizations that fight cybercrime coupled with the challenging political situation in the world results in the appearance of new threat groups who feel that they are safe. Another factor that helps cybercriminals make money by demanding ransoms is the fact that businesses underestimate this threat and lack proactive security tools.

If you wish to receive more detailed information about a specific incident, threat, or criminal group:

Please contact us.

We can conduct investigations to give you the maximum intelligence on the threats targeting your organization.

+65 3159 3798
+7 495 984 33 64
intelligence@group-ib.com